CYBER SECURITY LAB | IDS SIGNATURES

OWASP Top 10
Snort 탐지 룰

주요 취약점을 방어하기 위한 실무 환경 기반의 침입탐지시스템(IDS)
시그니처 작성 및 분석 가이드

A03:2021 - 인젝션 (SQL Injection)

SQL 인젝션은 가장 고전적이면서도 치명적인 공격입니다. 사용자 입력값에 SQL 특수문자나 키워드(UNION, SELECT, OR 1=1)가 포함되는지 검사하여 백엔드 데이터베이스를 보호합니다.

Snort Console

```
alert tcp $EXTERNAL_NET any → $HTTP_SERVERS $HTTP_PORTS
(msg:"SQL Injection - Universal Bypass Attempt"; flow:to
_server,established; content:"' or 1=1"; nocase; http_ur
i; classtype:web-application-attack; sid:1000001; rev:
1;)
```

전문 용어 해설

$EXTERNAL_NET: 외부 네트워크(공격자 측)를 의미하는 환경 변수입니다.

nocase: 대소문자를 구분하지 않고 패턴을 매칭하는 옵션입니다.

http_uri: HTTP 요청의 URI 부분에서만 패턴을 검색하여 탐지 효율을 높입니다.

A03:2021 - 크로스 사이트 스크립팅 (XSS)

웹 애플리케이션의 취약점을 이용하여 사용자의 브라우저에서 악성 스크립트가 실행되도록 유도하는 공격입니다. 주로 태그나 javascript 프로토콜의 유입을 탐지하여 차단합니다.

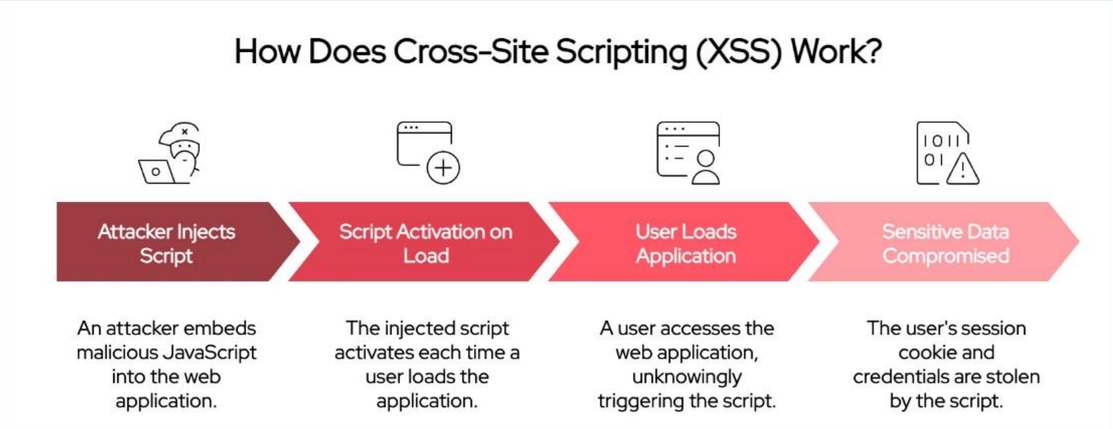
Snort Console

```
alert tcp $EXTERNAL_NET any → $HTTP_SERVERS $HTTP_PORTS
(msg:"XSS - Script Tag Attempt"; flow:to_server,establis
hed; content:""</div>; nocase; http_client_body; classty
pe:web-application-attack; sid:1000002; rev:1;)
```

전문 용어 해설

http_client_body: POST 방식 등으로 전송되는 HTTP 요청의 본문 영역에서 패턴을 찾습니다.

classtype: 탐지된 이벤트의 성격(예: web-application-attack)을 정의하여 관제 시 우선순위를 정하는 데 도움을 줍니다.



A01:2021 - 취약한 접근 제어

권한이 없는 사용자가 관리자 페이지나 시스템 중요 파일에 접근하는 것을 탐지합니다. 대표적으로 디렉터리 리스팅이나 경로 조작(../)을 통한 공격이 존재합니다.

Snort Console

```
alert tcp $EXTERNAL_NET any → $HTTP_SERVERS $HTTP_PORTS
(msg:"Exploit - Directory Traversal Attempt"; flow:to_se
rver,established; content:"../"; http_uri; classtype:att
empted-recon; sid:1000003; rev:1;)
```

전문 용어 해설

Directory Traversal (경로 이동): 상위 디렉터리로 이동하는 특수문자(../)를 이용해 허가되지 않은 시스템 파일(예: /etc/passwd)에 접근하는 기법입니다.

attempted-recon: 공격 전 정보를 수집하려는 정찰 시도를 의미하는 분류입니다.

설정 오류 및 불안전한 설계

A05:2021 - 보안 설정 오류

관리자 페이지가 외부에 노출되어 있거나, 기본 설정으로 방치된 경우를 탐지하여 정책 위반을 방지합니다.

Snort Console

```
alert tcp $EXTERNAL_NET any → $HTTP_SERVERS $HTTP_PORTS
(msg:"Unauthorized Admin Page Access"; content:"/admin/"; http_uri; classtype:policy-violation; sid:1000004;)
```

policy-violation

내부 보안 규정이나 정책상 허용되지 않은 접근이 발생했을 때 사용하는 분류 유형입니다.

A04:2021 - 불안전한 설계

비즈니스 로직의 허점을 노린 공격을 포함합니다. 특정 액션을 강제로 수행하게 하는 CSRF 요청 등을 감시합니다.

Snort Console

```
alert tcp $EXTERNAL_NET any → $HTTP_SERVERS $HTTP_PORTS
(msg:"Potential CSRF Attempt"; content:"transfer.php?amount="; http_uri; classtype:web-application-attack; sid:1000005;)
```

CSRF (사이트 간 요청 위조)

사용자가 의도하지 않았음에도 공격자가 의도한 비정상적인 요청(송금 등)을 서버에 전송하게 만드는 공격입니다.

OWASP Top 10 취약점별 Snort 대응 요약표

순위	항목명 (2021 기준)	주요 탐지 패턴 (Content)	비고
A01	취약한 접근 제어	`../`, `etc/passwd`, `.htaccess`	파일 시스템 접근 차단
A03	인젝션 (SQLi, XSS 등)	`' OR 1=1`, `</div>`, `UNION SELECT`	입력값 검증 우회 차단
A05	보안 설정 오류	`/admin`, `/config`, `test.php`	불필요한 경로 노출 감시
A10	서버 측 요청 위조(SSRF)	`http://169.254.169.254`	내부망 자원 (Cloud Metadata) 요청 감시

아키텍트 인사이트

Expert Insight

> 앞서 설명된 룰들은 교육을 목적으로 핵심 공격 패턴을 단순화한 것입니다.

실제 운영 환경에서는 공격자가 **URL Encoding**이나 **Hex Encoding** 기법을 통해 IDS 탐지를 쉽게 우회합니다. 따라서 단순 문자열 매칭(content)뿐만 아니라, **pcre (Perl Compatible Regular Expressions, 펄 호환 정규 표현식)**를 함께 사용하여 인코딩된 악성 페이로드까지 정교하게 필터링하는 최적화 과정이 반드시 수반되어야 합니다.

또한, 보안 룰의 강도만 높일 경우 내부 비즈니스 로직에서 발생하는 정상 트래픽까지 차단될 수 있으므로, 주기적인 로그 분석을 통한 **오탐(False Positive) 제거 작업**이 관제 시스템 운영의 성패를 좌우합니다.

Image Sources

https://png.pngtree.com/background/20250105/original/pngtree-dark-blue-cyber-security-background-design-picture-image_15514541.jpg

Source: pngtree.com

https://socradar.io/wp-content/uploads/2025/03/how-does-xss-work.png.webp

Source: socradar.io

https://static.vecteezy.com/system/resources/previews/069/165/012/non_2x/blue-neon-cloud-security-neon-icons-set-with-lock-shield-database-server-access-key-logo-for-data-protect-server-access-storage-systems-digital-encryption-symbol-ui-design-illustration-vector.jpg

Source: www.vecteezy.com